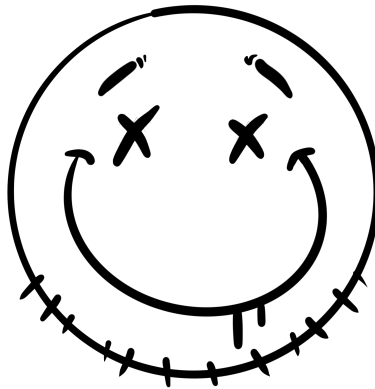




Lab 09: OS Hardening

Keith Schoen

CSEC3755-001

Dr. Daniel Pittman

8 April, 2026

Contents

1	Windows Hardening	1
1.1	Review User Accounts	1
1.2	Configure Password Policy	1
1.3	Configure Account Lockout Policy	2
1.4	Disable Unnecessary Services	3
2	Linux Hardening	4
2.1	Review User Accounts in /etc/passwd	4
2.2	Configure Password Policy via /etc/login.defs	4
2.3	Configure Account Lockout Policy via PAM	5
2.4	Review and Manage Services	7
3	CIS Benchmark Comparison	7
3.1	Linux CIS Benchmark Checks	7
3.2	Windows CIS Benchmark Checks	7
4	Security Policy Draft	7
5	Reflection Questions	7
5.1	Policy vs. Technical Controls	7
5.2	Defense in Depth	7

1 Windows Hardening

1.1 Review User Accounts

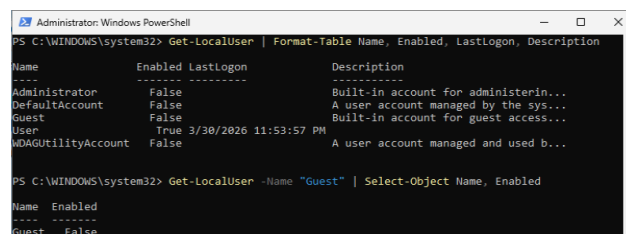


Figure 1: Screenshot showing all accounts and their enabled/disabled status.

From a hardening perspective, the guest account would count as an unnecessary access point. The guest account allows - although limited - access to a machine/network without any credentials eliminating the "hard part" for an attacker. This account is almost always unnecessary and should be disabled.

1.2 Configure Password Policy

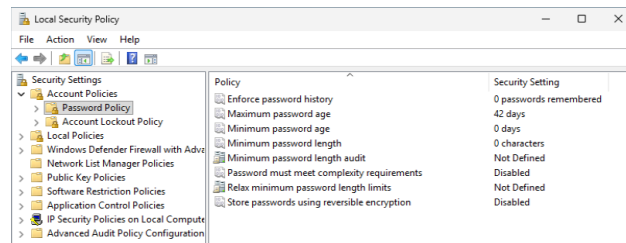


Figure 2: Screenshot showing default password policy

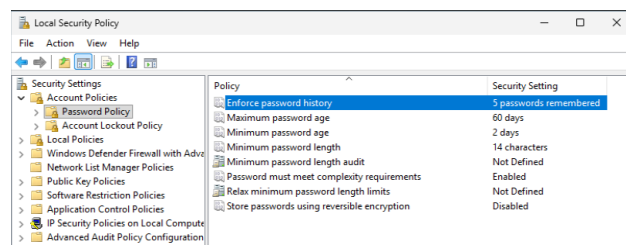


Figure 3: Screenshot showing updated password policy

People seem to hate coming up with and remembering passwords. Without having password minimums in place, everyone's password would be "user" and every machine and system

would be better off without password protection (at least people would be able to get on quicker!) To make sure that password protection is doing it's bare minimum, these simple policies must be put into place.

1.3 Configure Account Lockout Policy

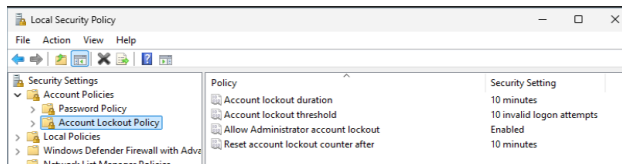


Figure 4: Screenshot showing default lockout policy

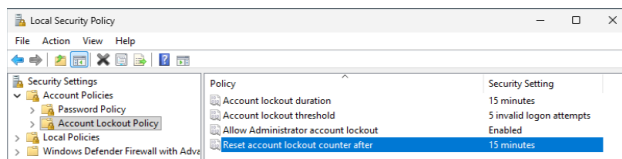
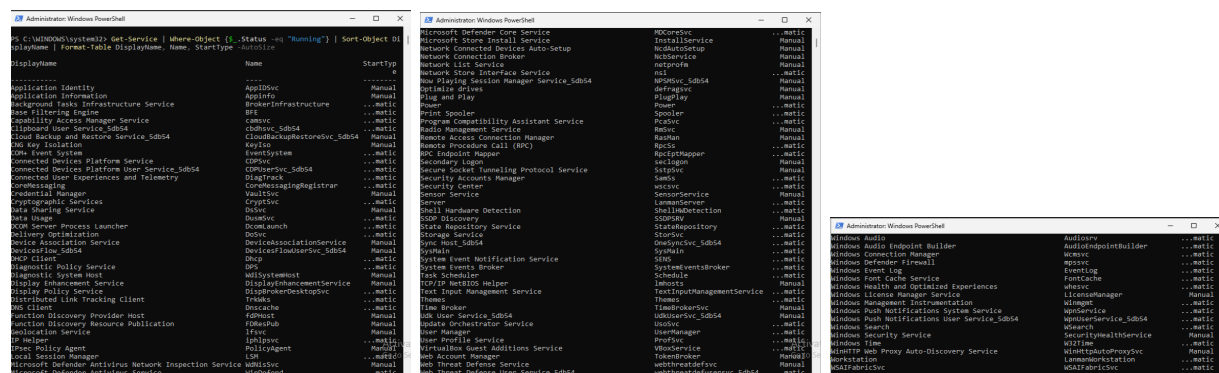


Figure 5: Screenshot showing updated lockout policy

It's not wise to give people too many tries or too much time with logging into an account. Adding just a little extra strictness to these policies makes it just that much more of a pain for even brute force tactics, hopefully making it not worth while.

1.4 Disable Unnecessary Services



Figures 6-8: Screenshots of the list of Running Services.

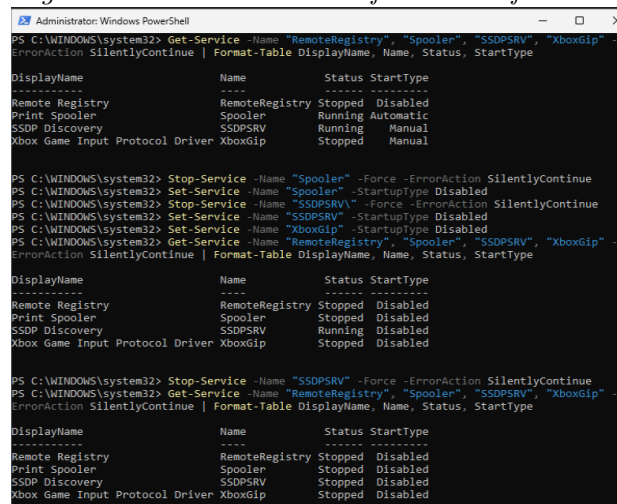


Figure 9: Screenshot of disabled services

I focused on the the 4 services that were stated as unnecessary for the VM. After running a check, I disabled the 3 that were running/enabled and stopped/disabled them.

2 Linux Hardening

2.1 Review User Accounts in /etc/passwd

```
(kali@kali)-[~]
└─$ cat /etc/passwd
root:x:0:0:root:/root:/usr/bin/zsh
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mail Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon:/usr/lib/dhcpcd:/bin/false
systemd-timesync:x:991:991:systemd Time Synchronization:/usr/sbin/nologin
messagebus:x:990:990:System Message Bus:/nonexistent:/usr/sbin/nologin
tcpdump:x:101:102::/nonexistent:/usr/sbin/nologin
rpc:x:102:65534:/run/rpcbind:/usr/sbin/nologin
sshd:x:989:65534:sshd user:/run/ssh:/usr/sbin/nologin
startd:x:103:65534:/var/lib/nfs:/usr/sbin/nologin
mysql:x:104:104:MySQL Server:/nonexistent:/bin/false
tss:x:105:106:TPM software stack:/var/lib/tpm:/bin/false
stunnel4:x:988:988:stunnel service system account:/var/run/stunnel4:/usr/sbin/nologin
ssh:x:106:107:/nonexistent:/usr/sbin/nologin
redsocks:x:107:110:/var/run/redsocks:/usr/sbin/nologin
systemd-oom:x:987:987:systemd Userspace OOM Killer:/usr/sbin/nologin
gophish:x:108:112:/var/lib/gophish:/usr/sbin/nologin
iodine:x:109:65534:/run/iodine:/usr/sbin/nologin

miredo:x:110:65534:/var/run/miredo:/usr/sbin/nologin
Debian-snmpp:x:111:113:/var/lib/snmpp:/bin/false
redis:x:112:114:/var/lib/redis:/usr/sbin/nologin
postgres:x:113:115:PostgreSQL administrator:/var/lib/postgresql:/bin/bash
mesquitto:x:114:117:/var/lib/mesquitto:/usr/sbin/nologin
dnsmasq:x:999:65534:dnsmasq:/var/lib/misc:/usr/sbin/nologin
avahi:x:115:119:Avahi mDNS daemon:/run/avahi-daemon:/usr/sbin/nologin
inetsim:x:116:120:/var/lib/inetsim:/usr/sbin/nologin
gvm:x:117:121:/var/lib/gvm:/usr/sbin/nologin
usbmux:x:118:46:usbmux daemon:/var/lib/usbmux:/usr/sbin/nologin
cups-pk-helper:x:119:122:user for cups-pk-helper service:/nonexistent:/usr/sbin/nologin
pipewire:x:986:986:system user for pipewire:/nonexistent:/usr/sbin/nologin
fwupd-refresh:x:985:985:Firmware update daemon:/var/lib/fwupd:/usr/sbin/nologin
geoclue:x:128:124:/var/lib/geoclue:/usr/sbin/nologin
gnome-remote-desktop:x:984:984:GNOME Remote Desktop:/var/lib/gnome-remote-desktop:/usr/sbin/nologin
saned:x:121:125:/var/lib/saned:/usr/sbin/nologin
polkitd:x:983:983:user for polkitd:/usr/sbin/nologin
rtkit:x:122:126:RealtimeKit:/proc:/usr/sbin/nologin
colord:x:982:982:colord colour management daemon:/var/lib/colord:/usr/sbin/nologin
pcscd:x:981:981:PC/SC Smart Card Daemon:/usr/sbin/nologin
Debian-gdm:x:900:900:Gnome Display Manager:/var/lib/gdm3:/bin/false
kali:x:1000:1000:Kali User,,,:/home/kali:/usr/bin/zsh
snort:x:123:130:Snort IDS:/var/log/snort:/usr/sbin/nologin
```

Figures 10-11: Screenshots of all accounts

```
(kali@kali)-[~]
└─$ awk -F: '{($3 == "0") {print}}' /etc/passwd
root:x:0:0:root:/root:/usr/bin/zsh
```

Figure 12: Screenshot of accounts with UID 0

```
(kali@kali)-[~]
└─$ grep -v '/nologin|/false' /etc/passwd
root:x:0:0:root:/root:/usr/bin/zsh
sync:x:4:65534:sync:/bin:/bin/sync
postgres:x:113:115:PostgreSQL administrator:/var/lib/postgresql:/bin/bash
kali:x:1000:1000:Kali User,,,:/home/kali:/usr/bin/zsh
```

Figure 13: Screenshot of accounts that can log in

2.2 Configure Password Policy via /etc/login.defs

```
(kali@kali)-[~]
└─$ gre -E "PASS_MAX_DAYS|PASS_MIN_DAYS|PASS_WARN_AGE|PASS_MIN_LEN" /etc/login.defs
Command 'gre' not found, did you mean:
  command 'grep' from deb grep
command 're' from deb re
command 'tre' from deb tre-command
command 'grc' from deb grc
command 'sre' from deb node-speech-rule-engine
command 'g2e' from deb python3-tatsu
command 'g2e' from deb python3-tatsu-lts
command 'gri' from deb gri
command 'gre' from deb firebird-utils
command 'gie' from deb proj-bin
command 'grn' from deb groff
command 'gle' from deb gle-graphics
Try: sudo apt install <deb name>
```

Figure 14: Screenshot of default password policies

```
# Password aging controls:
#
# PASS_MAX_DAYS Maximum number of days a password may be used.
# PASS_MIN_DAYS Minimum number of days allowed between password changes.
# PASS_WARN_AGE Number of days warning given before a password expires.
#
PASS_MAX_DAYS 90
PASS_MIN_DAYS 7
PASS_WARN_AGE 14
```

Figure 15: Screenshot of changes to password policy in `/etc/login.defs`

```
(kali@kali)~$ sudo chage -l kali
Last password change           : Jan 20, 2026
Password expires                : Apr 20, 2026
Password inactive              : never
Account expires                : never
Minimum number of days between password change : 7
Maximum number of days between password change : 90
Number of days of warning before password expires : 14
```

Figure 16: Screenshot of changes to existing user `kali`'s password policy

2.3 Configure Account Lockout Policy via PAM

```
(kali@kali)~$ cat /etc/pam.d/common-auth
#
# /etc/pam.d/common-auth - authentication settings common to all services
#
# This file is included from other service-specific PAM config files,
# and should contain a list of the authentication modules that define
# the central authentication scheme for use on the system
# (e.g., /etc/shadow, LDAP, Kerberos, etc.). The default is to use the
# traditional Unix authentication mechanisms.
#
# As of pam 1.0.1-6, this file is managed by pam-auth-update by default.
# To take advantage of this, it is recommended that you configure any
# local modules either before or after the default block, and use
# pam-auth-update to manage selection of other modules. See
# pam-auth-update(8) for details.
#
# here are the per-package modules (the "Primary" block)
auth [success=1 default=ignore] pam_unix.so nullok
# here's the fallback if no module succeeds
auth requisite pam_deny.so
# prime the stack with a positive return value if there isn't one already;
# this avoids us returning an error just because nothing sets a success code
# since the modules above will each just jump around
auth required pam_permit.so
# and here are more per-package modules (the "Additional" block)
# end of pam-auth-update config
```

Figure 17: Screenshot of current `/etc/pam.d/common-auth` file contents

```
auth required pam_faillock.so preauth silent deny=5 unlock_time=900
# here are the per-package modules (the "Primary" block)
auth [success=1 default=ignore] pam_unix.so nullok
auth [default=die] pam_faillock.so authfail deny=5 unlock_time=900
```

Figure 18: Screenshot of two lines added to `/etc/pam.d/common-auth` file

```
# and here are more per-package modules (the "Additional" block)
account required pam_faillock.so
# end of pam-auth-update config
```

Figure 19: Screenshot of line added to the end of `/etc/pam.d/common-account` file

```
(kali㉿kali)-[~]  
$ su - kali  
Password:  
su: Permission denied  
  
(kali㉿kali)-[~]  
$ su - kali  
Password:  
su: Permission denied  
  
(kali㉿kali)-[~]  
$ su - kali  
Password:  
su: Permission denied  
  
(kali㉿kali)-[~]  
$ su - kali  
Password:  
su: Permission denied  
  
(kali㉿kali)-[~]  
$ su - kali  
Password:  
su: Authentication failure  
  
(kali㉿kali)-[~]  
$ su - kali  
Password:  
su: Authentication failure
```

Figure 20: Screenshot of test. Five login attempts made to account kali using intentionally incorrect passwords. The sixth attempt was made using the correct password. Lockout is confirmed by continued denied access.

2.4 Review and Manage Services

2.5 SSH Hardening

3 CIS Benchmark Comparison

3.1 Linux CIS Benchmark Checks

3.2 Windows CIS Benchmark Checks

4 Security Policy Draft

5 Reflection Questions

5.1 Policy vs. Technical Controls

5.2 Defense in Depth

++report written with (minimal) help from Claude (Sonnet 4.6)++